P12 : Software Supply Chain

Partie 1 : Installer Harbor

1. Télécharger et extraire Harbor

```
arij@master:~/harbor$ ls -la
total 48
drwxrwxr-x  2 arij arij  4096 Nov  6 12:50 .
drwxr-x--- 18 arij arij  4096 Nov  6 12:50 ..
-rw-r--r--  1 arij arij 11347 Jun  4  2024 LICENSE
-rw-r--r--  1 arij arij  3646 Jun  4  2024 common.sh
-rw-r--r--  1 arij arij 14270 Jun  4  2024 harbor.yml.tmpl
-rwxr-xr-x  1 arij arij  1975 Jun  4  2024 install.sh
-rwxr-xr-x  1 arij arij  1882 Jun  4  2024 prepare
arij@master:~/harbor$
```

2. Créer et configurer harbor.yml +Lancer l'installation

```
[+] up 11/11
 ✔Network harbor_harbor       Created                                                                0.1s
 ✔Container harbor-log        Started                                                                1.1s
 ✔Container registry          Started                                                                5.4s
 ✔Container redis             Started                                                                4.2s
 ✔Container registryctl       Started                                                                1.6s
 ✔Container harbor-portal     Started                                                                6.7s
 ✔Container harbor-db         Started                                                                2.4s
 ✔Container trivy-adapter     Started                                                                4.6s
 ✔Container harbor-core       Started                                                                7.1s
 ✔Container nginx             Started                                                                7.9s
 ✔Container harbor-jobservice Started                                                                9.8s
✔----Harbor has been installed and started successfully.----
arij@master:~/harbor$
```

3.Vérification

```
arij@master:~/harbor$ sudo docker compose ps
WARN[0000] /home/arij/harbor/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid p
otential confusion
NAME                IMAGE                                   COMMAND                  SERVICE         CREATED             STATUS
                    PORTS
harbor-core         goharbor/harbor-core:v2.11.0            "/harbor/entrypoint.…"   core            About an hour ago   Up 5 seconds
 (health: starting)
harbor-db           goharbor/harbor-db:v2.11.0              "/docker-entrypoint.…"   postgresql      About an hour ago   Up 7 seconds
 (health: starting)
harbor-jobservice   goharbor/harbor-jobservice:v2.11.0      "/harbor/entrypoint.…"   jobservice      About an hour ago   Up 2 seconds
 (health: starting)
harbor-log          goharbor/harbor-log:v2.11.0             "/bin/sh -c /usr/loc…"   log             About an hour ago   Up 22 minute
s (healthy)           127.0.0.1:1514->10514/tcp
harbor-portal       goharbor/harbor-portal:v2.11.0          "nginx -g 'daemon of…"   portal          About an hour ago   Up 8 seconds
 (health: starting)
nginx               goharbor/nginx-photon:v2.11.0           "nginx -g 'daemon of…"   proxy           About an hour ago   Up 4 seconds
 (health: starting)    0.0.0.0:80->8080/tcp, [::]:80->8080/tcp
redis               goharbor/redis-photon:v2.11.0           "redis-server /etc/r…"   redis           About an hour ago   Up 11 second
s (health: starting)
registry            goharbor/registry-photon:v2.11.0        "/home/harbor/entryp…"   registry        About an hour ago   Up 6 seconds
 (health: starting)
registryctl         goharbor/harbor-registryctl:v2.11.0     "/home/harbor/start.…"   registryctl     About an hour ago   Up 9 seconds
 (health: starting)
trivy-adapter       goharbor/trivy-adapter-photon:v2.11.0   "/home/scanner/entry…"   trivy-adapter   About an hour ago   Up 11 second
s (health: starting)
```

4. configure le DNS sur VM Harbor

```
arij@master:~/harbor$ cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 ubuntu26

# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
192.168.159.15 master
192.168.159.16 worker1
192.168.159.17 worker2
192.168.159.15  harbor.lab.local
arij@master:~/harbor$
```

5. Sur la VM de lab

```
  GNU nano 7.2                                        /etc/hosts *
127.0.0.1 localhost
127.0.1.1 vagrant
192.168.159.15  harbor.lab.local
# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Et

```
 GNU nano 7.2                                  /etc/docker/daemon.json *
{
  "ipv6": false,
  "dns": ["8.8.8.8", "1.1.1.1"],
  "insecure-registries": ["harbor.lab.local"]
}
```

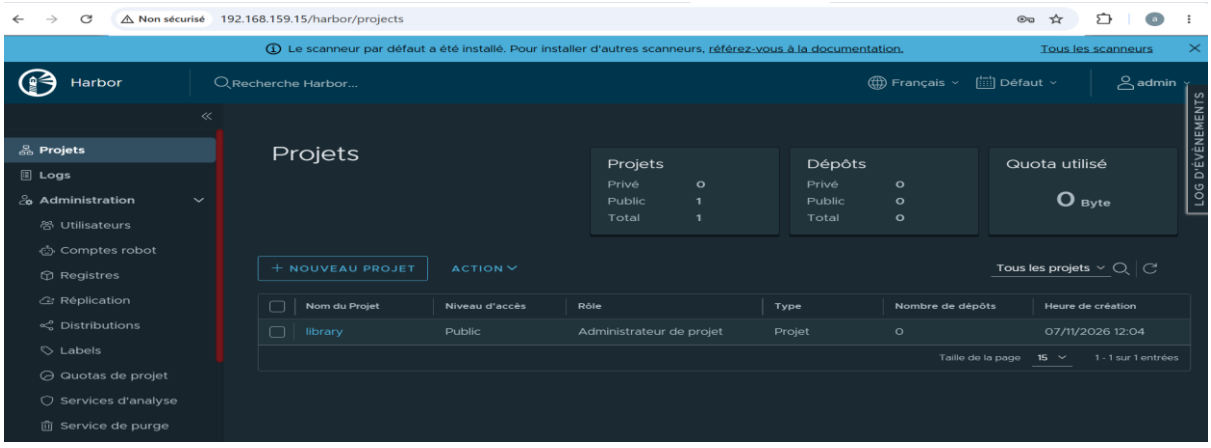
6. Vérifier la connexion à Harbor

```
arij@master:~/harbor$ curl http://localhost
<!DOCTYPE html>
<html>
    <head>
        <meta charset="utf-8"/>
        <title>Harbor</title>
        <base href="/"/>
        <meta name="viewport" content="width=device-width, initial-scale=1"/>
        <link rel="icon" type="image/x-icon" href="favicon.ico?v=2"/>
    <link rel="stylesheet" href="styles.75cb4562f0127450.css"></head>
    <body>
        <harbor-app>
            <div class="spinner spinner-lg app-loading app-loading-fixed">
                Loading...
            </div>
        </harbor-app>
    <script src="runtime.2786db5c4282d8cb.js" type="module"></script><script src="polyfills.67cfd31b2752cc11.js" type="module"></scri
pt><script src="scripts.3846d86d42cdb753.js" defer></script><script src="main.782b5181ceecb1db.js" type="module"></script></body>
</html>
arij@master:~/harbor$
```

7. tester depuis la VM de lab

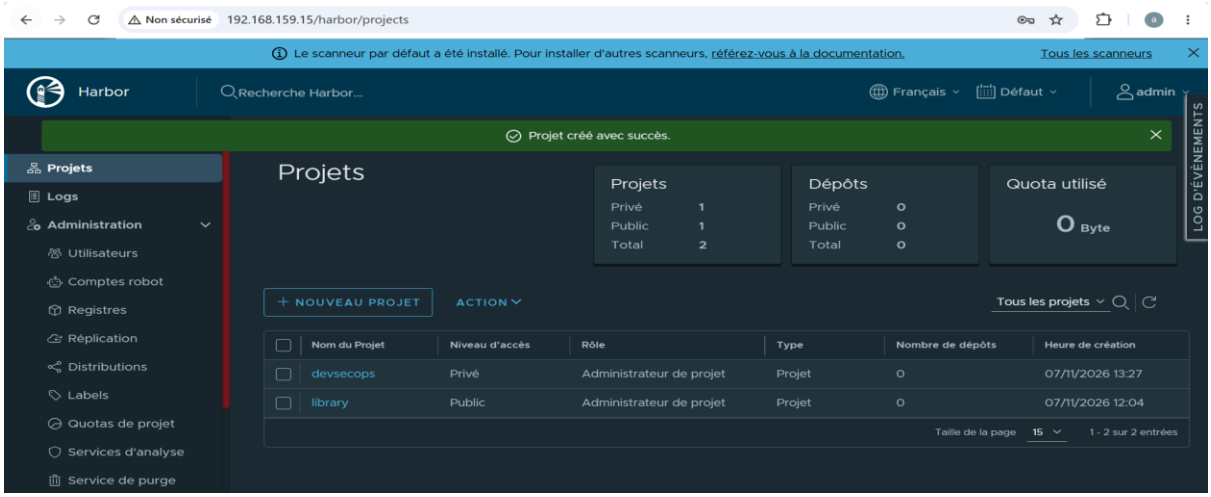
```
arij@vagrant:~/DevOps_tp12$ curl http://harbor.lab.local
<!DOCTYPE html>
<html>
    <head>
        <meta charset="utf-8"/>
        <title>Harbor</title>
        <base href="/"/>
        <meta name="viewport" content="width=device-width, initial-scale=1"/>
        <link rel="icon" type="image/x-icon" href="favicon.ico?v=2"/>
    <link rel="stylesheet" href="styles.75cb4562f0127450.css"></head>
    <body>
        <harbor-app>
            <div class="spinner spinner-lg app-loading app-loading-fixed">
                Loading...
            </div>
        </harbor-app>
    <script src="runtime.2786db5c4282d8cb.js" type="module"></script><script src="polyfills.67cfd31b2752cc11.js" type="module"></scri
pt><script src="scripts.3846d86d42cdb753.js" defer></script><script src="main.782b5181ceecb1db.js" type="module"></script></body>
</html>
arij@vagrant:~/DevOps_tp12$
```

8.Tester via navigateur :

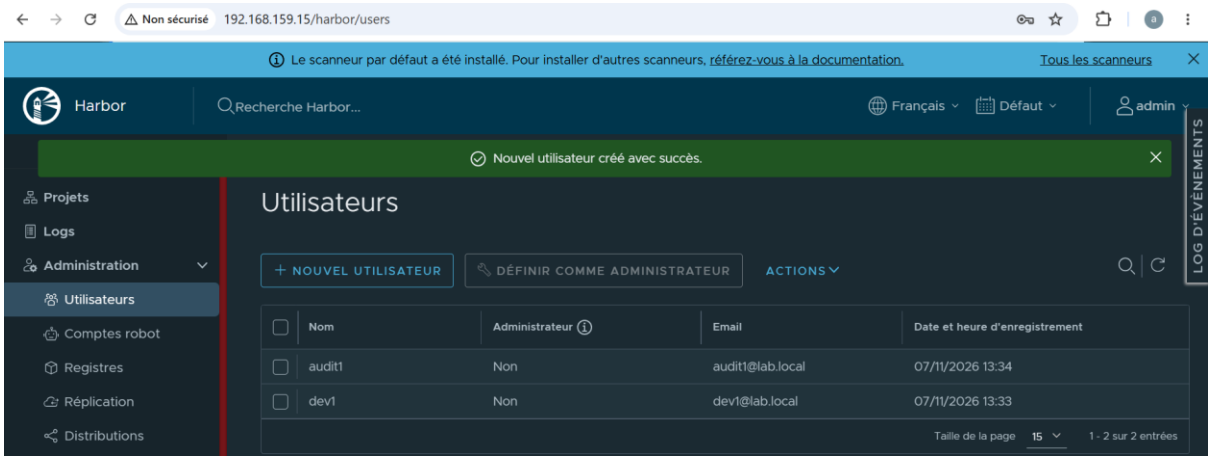


Partie 2 : Projets, RBAC, scan et rétention

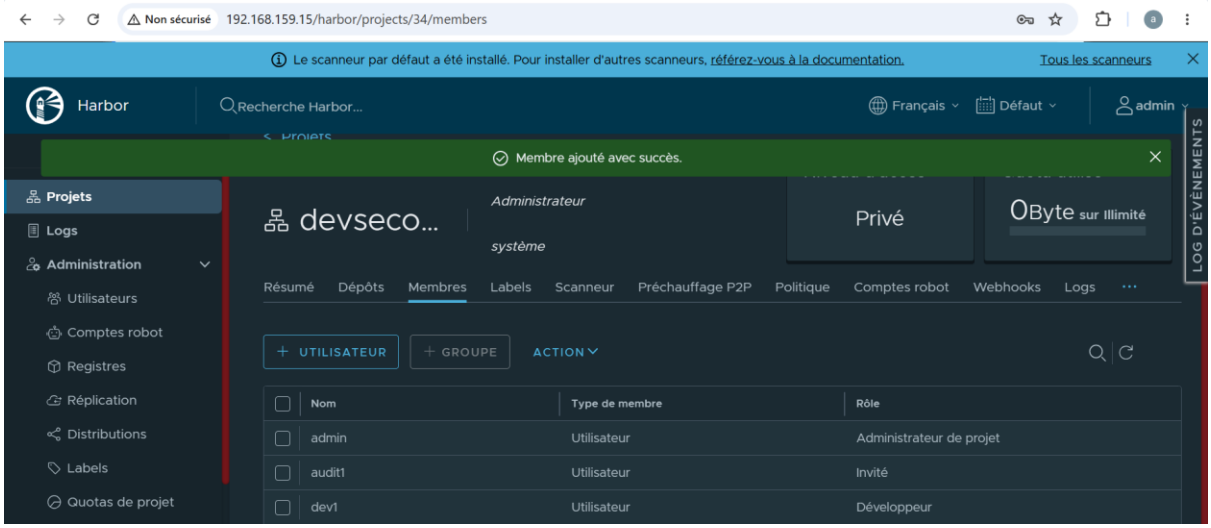
1. Créer le projet privé devsecops



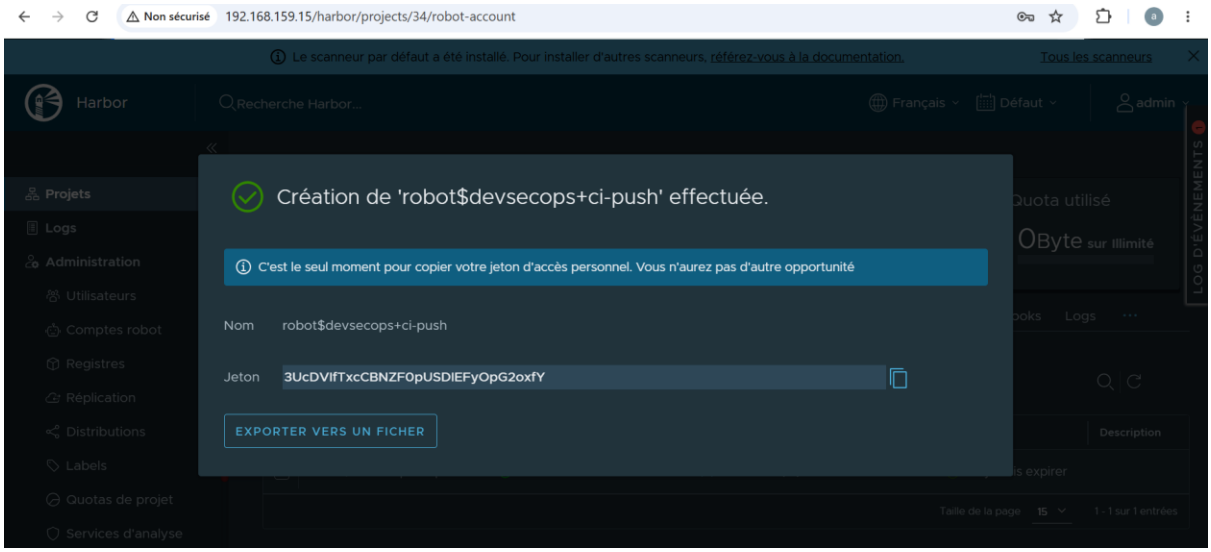
2. Créer les utilisateurs



3. Ajouter les membres au projet



4. Créer le robot account :



5. Taguer l'image pour Harbor

```
arij@vagrant:~/DevOps_tp12$ docker tag nginx:latest contact-api:latest
arij@vagrant:~/DevOps_tp12$ docker images | grep contact-api
WARNING: This output is designed for human readability. For machine-readable output, please use --format.
arijbelaid.io/contact-api:5d58b6c     45f43ab2b8b7       316MB          75MB
arijbelaid/contact-api:64b61c7        028ba941c8d2       316MB          75MB
arijbelaid/contact-api:86d278f        89b3aa1a23c9       316MB          75MB
arijbelaid/contact-api:ec663a0        64b91ac29540       316MB          75MB
arijbelaid/contact-api:fcfe432        f29eedfaaebd       316MB          75MB
arijbelaid/contact-api:latest-main    64b91ac29540       316MB          75MB
arijbelaid/contact-api:test-push      7c29e611d78f       316MB          75MB
arjbelaid/contact-api:0620deb         0211fa995b67       316MB          75MB
arjbelaid/contact-api:0e0b7ac         6a4cb1056449       316MB          75MB
arjbelaid/contact-api:10a1171         ca11881eccae       318MB         75.8MB
arjbelaid/contact-api:175fe72         97025e4a7e67       318MB         75.8MB
arjbelaid/contact-api:1db7b60         b9f649bdd947       320MB         77.1MB
arjbelaid/contact-api:1f814d0         9c75206b6b65       318MB         75.8MB
arjbelaid/contact-api:286e07c         344159f705cd       316MB          75MB
arjbelaid/contact-api:29d13b9         abd7fc90bc24       316MB          75MB
arjbelaid/contact-api:2f5e4ca         8d194258a6f3       318MB         75.8MB
arjbelaid/contact-api:3917ba1         20becf775557       316MB          75MB
arjbelaid/contact-api:71f0058         01384a578058       316MB          75MB
arjbelaid/contact-api:7b62f5c         483400d38b2d       316MB          75MB
arjbelaid/contact-api:8960cf1         4aabef1a5744       316MB          75MB
arjbelaid/contact-api:9160656         7ecd4bfe3a0a       316MB          75MB
arjbelaid/contact-api:c92a56e         958355efb4ae       316MB          75MB
arjbelaid/contact-api:ca0d13c         2e884c64119b       316MB          75MB
arjbelaid/contact-api:f0c091b         3b028bc72bc6       316MB          75MB
arjbelaid/contact-api:f764b7c         69cc9acbe697       316MB          75MB
contact-api:latest                    165ddde8751e       243MB         66.8MB
```

6. Se connecter à Harbor avec le robot account

```
arij@vagrant:~/DevOps_tp12$ docker login harbor.lab.local -u 'robot$devsecops+ci-push' -p '3UcDVIfTxcCBNZF0pUSDIEFyOpG2oxfY'
WARNING! Using --password via the CLI is insecure. Use --password-stdin.

WARNING! Your credentials are stored unencrypted in '/home/arij/.docker/config.json'.
Configure a credential helper to remove this warning. See
https://docs.docker.com/go/credential-store/

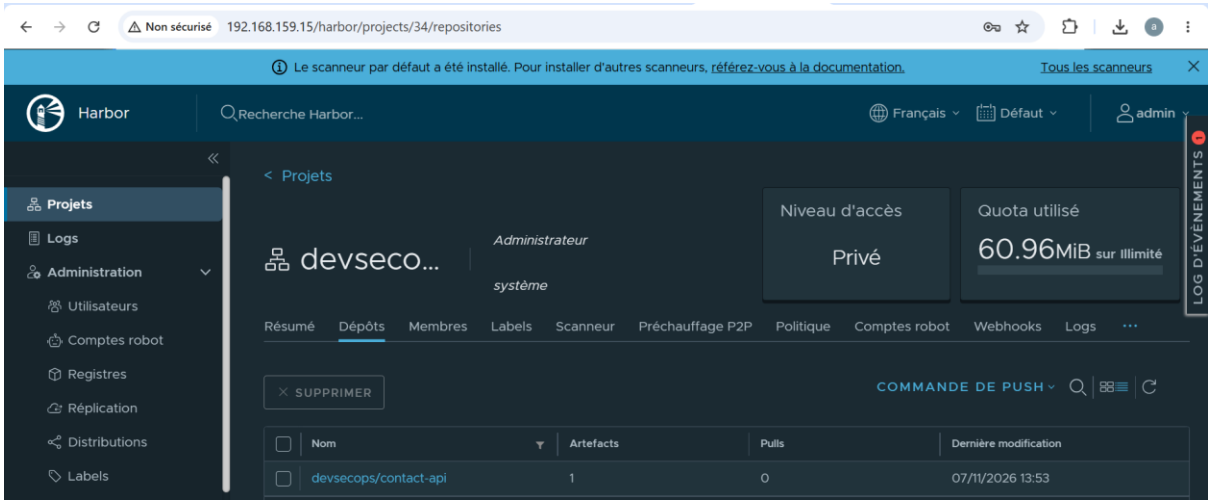
Login Succeeded
arij@vagrant:~/DevOps_tp12$
```

7. Taguer pour Harbor et pousser

```
arij@vagrant:~/DevOps_tp12$ docker tag contact-api:latest harbor.lab.local/devsecops/contact-api:1.0.0
arij@vagrant:~/DevOps_tp12$ docker push harbor.lab.local/devsecops/contact-api:1.0.0
The push refers to repository [harbor.lab.local/devsecops/contact-api]
6d2e43921e9e: Pushed
1724c05f72c6: Pushed
37fb86c2a767: Pushed
512ac5e7ce8e: Pushed
1962e1ff75b4: Pushed
7cb4701ce7cd: Pushed
bbb080c71d50: Pushed
1.0.0: digest: sha256:5cb45c65713151f856f6b64f6a9b6a96b74d6a10709a7aa18919a444fd00bffa size: 2290

i Info → Not all multiplatform-content is present and only the available single-platform image was pushed
        sha256:165ddde8751e75a1c907d24ef10d9f6deb08b57e0fe56caf67512486aff76d82 -> sha256:5cb45c65713151f856f6b64f6a9b6a96b74d6a1070
9a7aa18919a444fd00bffa
arij@vagrant:~/DevOps_tp12$
```

8. Vérifier dans Harbor



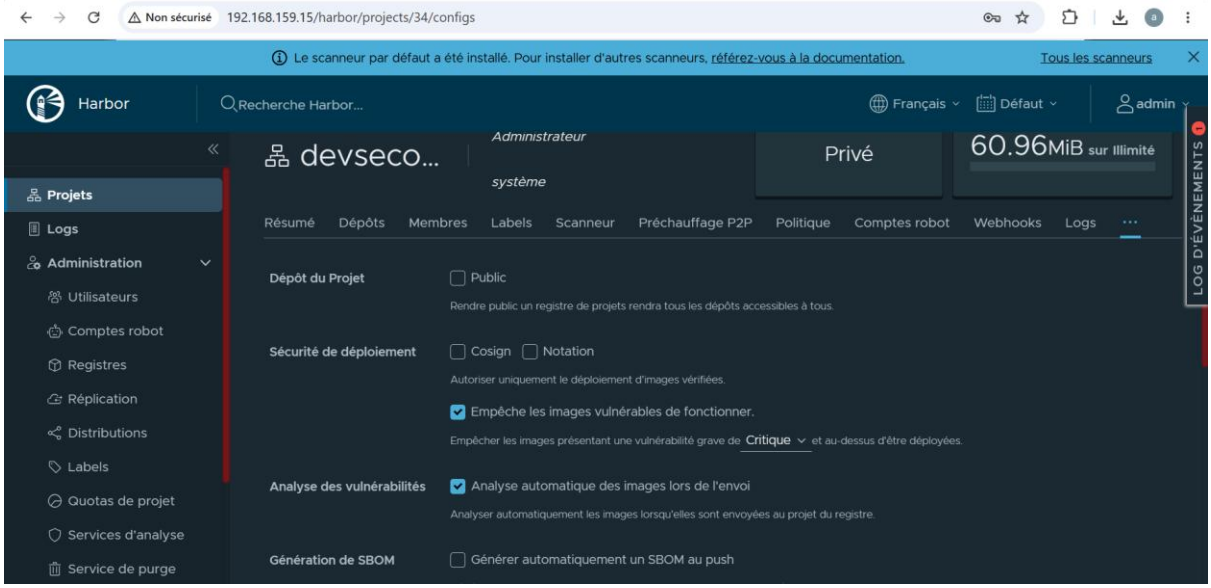
9. teste le RBAC

```
arij@vagrant:~/DevOps_tp12$ docker login harbor.lab.local -u audit1 -p 'Audit1Password!'
WARNING! Using --password via the CLI is insecure. Use --password-stdin.

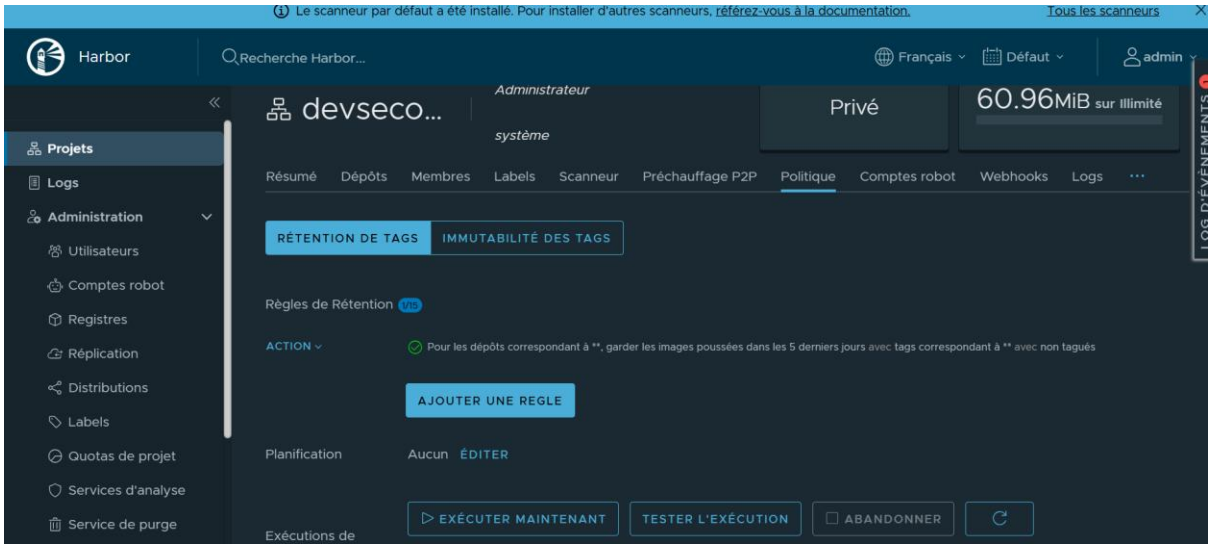
WARNING! Your credentials are stored unencrypted in '/home/arij/.docker/config.json'.
Configure a credential helper to remove this warning. See
https://docs.docker.com/go/credential-store/

Login Succeeded
arij@vagrant:~/DevOps_tp12$ docker tag contact-api:latest harbor.lab.local/devsecops/contact-api:2.0.0
arij@vagrant:~/DevOps_tp12$ docker push harbor.lab.local/devsecops/contact-api:2.0.0
The push refers to repository [harbor.lab.local/devsecops/contact-api]
1962e1ff75b4: Layer already exists
7cb4701ce7cd: Layer already exists
37fb86c2a767: Layer already exists
512ac5e7ce8e: Layer already exists
6d2e43921e9e: Layer already exists
1724c05f72c6: Layer already exists
bbb080c71d50: Layer already exists
error from registry: unauthorized to access repository: devsecops/contact-api, action: push: unauthorized to access repository: devse
cops/contact-api, action: push
arij@vagrant:~/DevOps_tp12$
```

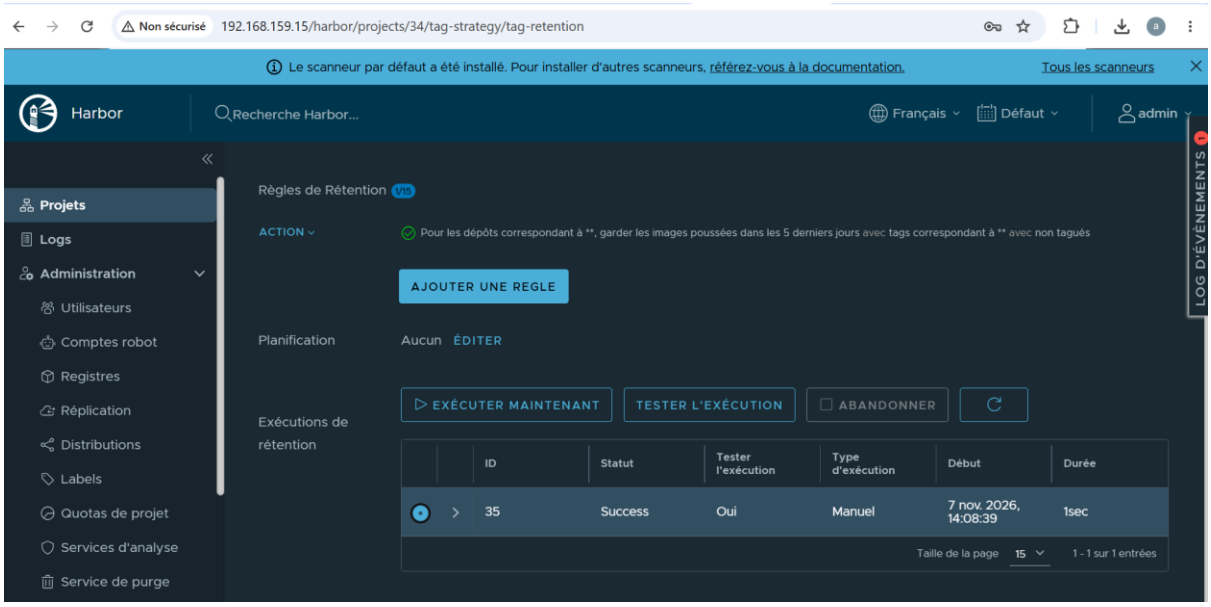
10. Activer le scan et le blocage



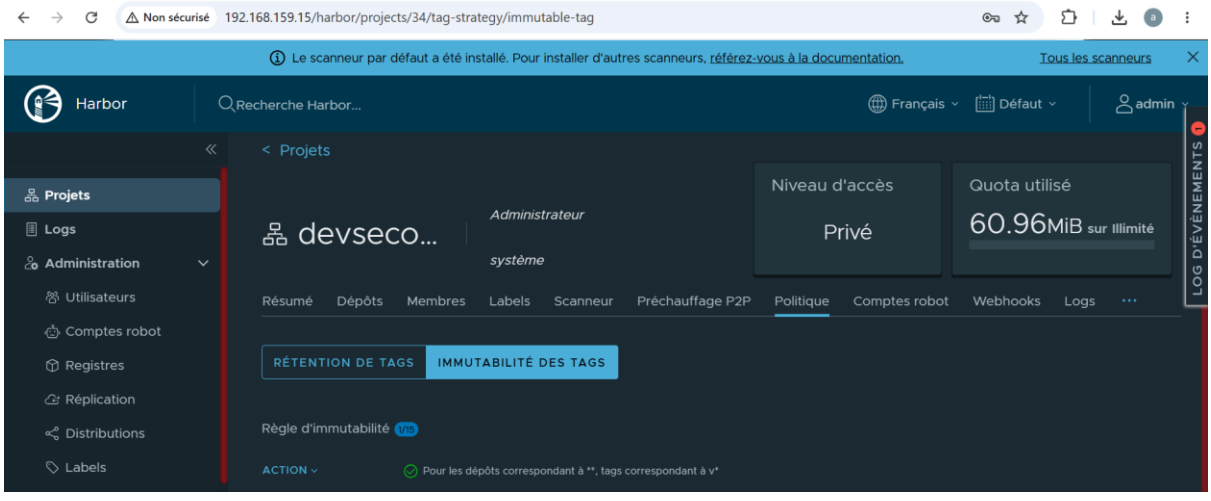
11. Configurer la rétention des tags



12. Lancer le Dry Run



13. Configurer l'immutabilité des tags



14. tester le blocage d'une image vulnérable

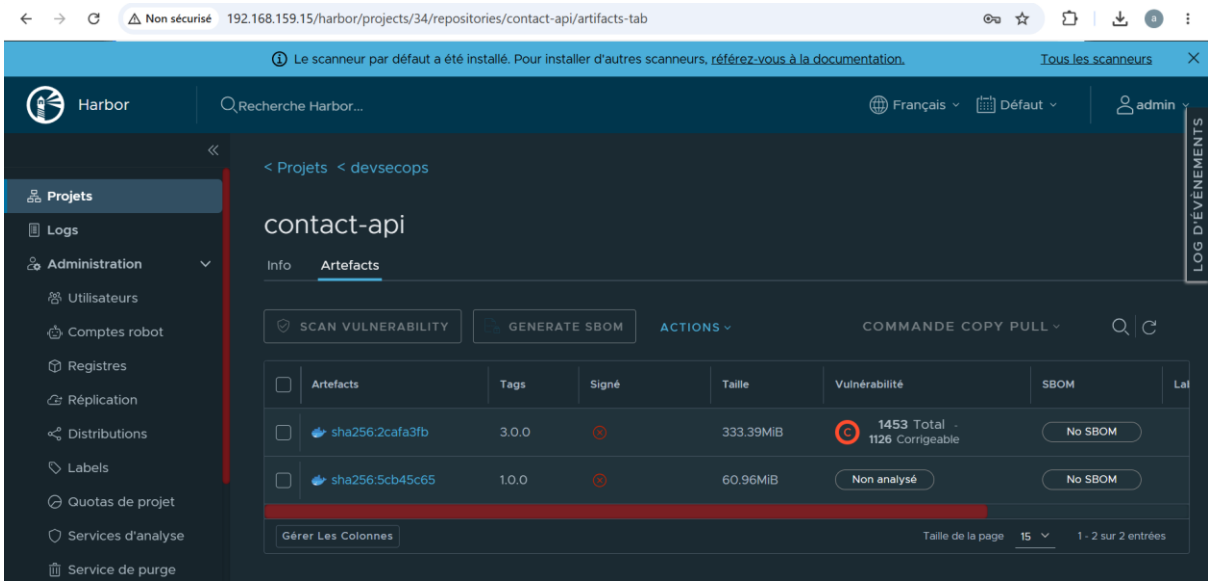
```
arij@vagrant:~/DevOps_tp12$ docker login harbor.lab.local -u 'robot$devsecops+ci-push' -p '3UcDVIfTxcCBNZF0pUSDIEFyOpG2oxfY'
WARNING! Using --password via the CLI is insecure. Use --password-stdin.

WARNING! Your credentials are stored unencrypted in '/home/arij/.docker/config.json'.
Configure a credential helper to remove this warning. See
https://docs.docker.com/go/credential-store/

Login Succeeded
arij@vagrant:~/DevOps_tp12$ docker push harbor.lab.local/devsecops/contact-api:3.0.0
The push refers to repository [harbor.lab.local/devsecops/contact-api]
1de76e268b10: Pushed
d9a8df589451: Pushed
6f51ee005dea: Pushed
5f32ed3c3f27: Pushed
0d27a8e86132: Pushed
2ff1d7c41c74: Pushed
b253aeafeaa7: Pushed
3d2201bd995c: Pushed
0c8cc2f24a4d: Pushed
3.0.0: digest: sha256:2cafa3fbb0b6529ee4726b4f599ec27ee557ea3dea7019182323b3779959927f size: 2215

i Info → Not all multiplatform-content is present and only the available single-platform image was pushed
          sha256:a158d3b9b4e3fa813fa6c8c590b8f0a860e015ad4e59bbce5744d2f6fd8461aa -> sha256:2cafa3fbb0b6529ee4726b4f599ec27ee557ea3dea
7019182323b3779959927f
arij@vagrant:~/DevOps_tp12$
```

15. Vérifier le scan Trivy dans Harbor



Partie 3 : SBOM avec Syft, scan avec Grype

1. Générer le SBOM avec Syft

```
arij@vagrant:~/DevOps_tp12$
docker run --rm -v /var/run/docker.sock:/var/run/docker.sock -v "$PWD:/out" anchore/syft:latest \
  contact-api:latest -o spdx-json=/out/contact-api.spdx.json -o cyclonedx-json=/out/contact-api.cdx.json
arij@vagrant:~/DevOps_tp12$ ls -la *.json
-rw-r--r-- 1 root root 1262909 nov.   7 17:10 contact-api.cdx.json
-rw-r--r-- 1 root root 2874235 nov.   7 17:10 contact-api.spdx.json
```

2.Analyser le SBOM

```
arij@vagrant:~/DevOps_tp12$ sudo apt install -y jq
[sudo] password for arij:
Lecture des listes de paquets... Fait
Construction de l'arbre des dépendances... Fait
Lecture des informations d'état... Fait
jq est déjà la version la plus récente (1.7.1-3ubuntu0.24.04.2).
jq passé en « installé manuellement ».
0 mis à jour, 0 nouvellement installés, 0 à enlever et 83 non mis à jour.
arij@vagrant:~/DevOps_tp12$ cat contact-api.spdx.json | jq '.packages | length'
154
arij@vagrant:~/DevOps_tp12$ cat contact-api.spdx.json | jq '.packages[] | select(.name | test("express"; "i")) | {name, versionInfo}'
arij@vagrant:~/DevOps_tp12$ cat contact-api.spdx.json | jq '.packages[] | select(.name | test("openssl"; "i")) | {name, versionInfo}'
{
  "name": "openssl",
  "versionInfo": "3.5.7-1~deb13u3"
}
{
  "name": "openssl-provider-legacy",
  "versionInfo": "3.5.7-1~deb13u3"
}
```

3. Analyser le SBOM avec Grype

```
arij@vagrant:~/DevOps_tp12$ docker run --rm -v "$PWD:/in" anchore/grype:latest sbom:/in/contact-api.spdx.json
NAME                INSTALLED                          FIXED IN     TYPE  VULNERABILITY     SEVERITY    EPSS           RISK
libgnutls30t64      3.8.9-3+deb13u4                                 deb   CVE-2011-3389     Negligible  73.3% (99th)   3.7
nginx               1.31.8-1~trixie                                 deb   CVE-2009-4487     Negligible  26.8% (98th)   1.3
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-9079     Critical    1.1% (64th)    1.0
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-9079     Critical    1.1% (64th)    1.0
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-92391    High        1.2% (67th)    0.9
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-92391    High        1.2% (67th)    0.9
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-86409    High        1.1% (65th)    0.9
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-86409    High        1.1% (65th)    0.9
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-92387    High        1.0% (64th)    0.8
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-92387    High        1.0% (64th)    0.8
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-87862    High        1.0% (62nd)    0.8
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-87862    High        1.0% (62nd)    0.8
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-19931    Critical    0.7% (55th)    0.7
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-19931    Critical    0.7% (55th)    0.7
libtiff6            4.7.0-3+deb13u3                    (won't fix)  deb   CVE-2026-52490    Critical    0.7% (54th)    0.7
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-11856    Critical    0.7% (52nd)    0.6
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-11856    Critical    0.7% (52nd)    0.6
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-87863    High        0.8% (57th)    0.6
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-87864    High        0.8% (57th)    0.6
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-92386    High        0.8% (57th)    0.6
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-87863    High        0.8% (57th)    0.6
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-87864    High        0.8% (57th)    0.6
libcurl4t64         8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-92386    High        0.8% (57th)    0.6
curl                8.14.1-2+deb13u7                   (won't fix)  deb   CVE-2026-92388    Critical    0.7% (53rd)    0.6
```

Partie 4 : Signer et vérifier avec Cosign

1. Installer Cosign

```
arij@vagrant:~/DevOps_tp12$ cosign version
  ______   ______        _______. __    _______ .__   __.
 /      | /      |      /       ||  |  /  _____||  \ |  |
|  ,----'|  ,----'     |   (----`|  | |  |  __  |   \|  |
|  |     |  |           \   \    |  | |  | |_ | |  . `  |
|  `----.|  `----.  .----)   |   |  | |  |__| | |  |\   |
 \______| \______/  |_______/    |__|  \______| |__| \__|
cosign: A tool for Container Signing, Verification and Storage in an OCI registry.

GitVersion:    devel
GitCommit:     unknown
GitTreeState:  unknown
BuildDate:     unknown
GoVersion:     go1.24.1
Compiler:      gc
Platform:      linux/amd64
```

2. Générer la paire de clés

```
arij@vagrant:~/DevOps_tp12$ cosign generate-key-pair
Enter password for private key:
Enter password for private key again:
Private key written to cosign.key
Public key written to cosign.pub
arij@vagrant:~/DevOps_tp12$ echo "cosign.key" >> .gitignore
arij@vagrant:~/DevOps_tp12$
```

3. Récupérer *token d'authentification* et le digest de l'image

```
arij@vagrant:~/DevOps_tp12$ docker login harbor.lab.local -u 'robot$devsecops+ci-push' -p '3UcDVIfTxcCBNZF0pUSDIEFyOpG2oxfY'
WARNING! Using --password via the CLI is insecure. Use --password-stdin.
Login Succeeded
arij@vagrant:~/DevOps_tp12$ TOKEN=$(curl -s -u 'robot$devsecops+ci-push:3UcDVIfTxcCBNZF0pUSDIEFyOpG2oxfY' \
  "http://harbor.lab.local/service/token?service=harbor-registry&scope=repository:devsecops/contact-api:pull" \
  | jq -r '.token')
arij@vagrant:~/DevOps_tp12$ DIGEST=$(curl -s -I -H "Authorization: Bearer $TOKEN" \
  -H "Accept: application/vnd.docker.distribution.manifest.v2+json" \
  http://harbor.lab.local/v2/devsecops/contact-api/manifests/1.0.0 | \
  grep -i "Docker-Content-Digest" | awk '{print $2}' | tr -d '\r')
arij@vagrant:~/DevOps_tp12$ echo $DIGEST
```

4. Signer l'image

```
arij@vagrant:~/DevOps_tp12$ cosign sign --key cosign.key --allow-http-registry --allow-insecure-registry \
  harbor.lab.local/devsecops/contact-api@$DIGEST
Enter password for private key:
WARNING: "harbor.lab.local/devsecops/contact-api" appears to be a private repository, please confirm uploading to the transparency lo
g at "https://rekor.sigstore.dev"
Are you sure you would like to continue? [y/N] y

        The sigstore service, hosted by sigstore a Series of LF Projects, LLC, is provided pursuant to the Hosted Project Tools Terms
 of Use, available at https://lfprojects.org/policies/hosted-project-tools-terms-of-use/.
        Note that if your submission includes personal data associated with this signed artifact, it will be part of an immutable rec
ord.
        This may include the email address associated with the account with which you authenticate your contractual Agreement.
        This information will be used for signing this artifact and will be stored in public transparency logs and cannot be removed
later, and is subject to the Immutable Record notice at https://lfprojects.org/policies/hosted-project-tools-immutable-records/.

By typing 'y', you attest that (1) you are not submitting the personal data of any other person; and (2) you understand and agree to
the statement and the Agreement terms at the URLs listed above.
Are you sure you would like to continue? [y/N] y
tlog entry created with index: 3742360844
Pushing signature to: harbor.lab.local/devsecops/contact-api
```

5. Vérifier la signature

```
arij@vagrant:~/DevOps_tp12$ cosign verify --key cosign.pub --allow-http-registry --allow-insecure-registry \
  harbor.lab.local/devsecops/contact-api@$DIGEST

Verification for harbor.lab.local/devsecops/contact-api@sha256:165ddde8751e75a1c907d24ef10d9f6deb08b57e0fe56caf67512486aff76d82 --
The following checks were performed on each of these signatures:
  - The cosign claims were validated
  - Existence of the claims in the transparency log was verified offline
  - The signatures were verified against the specified public key

[{"critical":{"identity":{"docker-reference":"harbor.lab.local/devsecops/contact-api"},"image":{"docker-manifest-digest":"sha256:165d
dde8751e75a1c907d24ef10d9f6deb08b57e0fe56caf67512486aff76d82"},"type":"cosign container image signature"},"optional":{"Bundle":{"Sign
edEntryTimestamp":"MEYCIQD6L7vKRnHsgeCxmXP4wLyFq7C3M5lsw43iksJF1TY9WQIhANehxCVQayjAuacRM/8AVQNqluQTophVuJs9aAd/UEkT","Payload":{"body
":"eyJhcGlWZXJzaW9uIjoiMC4wLjEiLCJraW5kIjoiaGFzaGVkcmVrb3JkIiwic3BlYyI6eyJkYXRhIjp7Imhhc2giOnsiYWxnb3JpdGhtIjoic2hhMjU2IiwidmFsdWUiOi
IxMmZkNjg5Y2UzZTljMWVhZTBhNmRiZDUyZDkxMTA4MjUwYzA0YmMxZjExYTdlZTFkMGE5ZWY0Y2YxOGMwOTVjIn19LCJzaWduYXR1cmUiOnsiY29udGVudCI6Ik1FVUNJSHB
WRUxWdUJkTEtIWkNtc3phUUNPQ0xJY0xacFNiT3NXNHovek5DRDFwUkFpRUFpT0V2MFNreDJkaVRib0V6Y2NaNkIzeHE2czJONXdoY0ZUOEpJVXpVNnFjPSIsInB1YmxpY0tl
eSI6eyJjb250ZW50IjoiTFMwdExTMUNSVWRKVGlCUVZVSk1TVU1nUzBWWkxTMHRMUzBLVFVacmQwVjNXVWhMYjFwSmVtb3dRMEZSV1VsTGIxcEplbW93UkVGUlkwUlJaMEZGU
jNWRU1VRlpZVmc1Y0RGaWFWUkJNazFsUkVoeVpqUkVXalowYkFvM04yazRXazFrY0RsclkzRTRNRzlPY0VReVZtRnBjemN2WW5odFdrZG5kbTFYWmtGWVZtVldObVpNUVZZMV
ZsTTJNemhRZERWU1RteDNQVDBLTFMwdExTMUZUa1FnVUZWQ1RFbERJRXRGV1MwdExTMHRDZz09In19fX0=","integratedTime":1794073076,"logIndex":3742360844
,"logID":"c0d23d6ad406973f9559f3ba2d1ca01f8414d7d8ffc5b8445c224f98b9591801d"}}}}]
```

6.Attacher le SBOM comme attestation

```
arij@vagrant:~/DevOps_tp12$ cosign attest --key cosign.key --type spdxjson --predicate contact-api.spdx.json \
  --allow-http-registry --allow-insecure-registry \
  harbor.lab.local/devsecops/contact-api@$DIGEST
Enter password for private key:
Using payload from: contact-api.spdx.json
WARNING: "harbor.lab.local/devsecops/contact-api" appears to be a private repository, please confirm uploading to the transparency lo
g at "https://rekor.sigstore.dev"
Are you sure you would like to continue? [y/N] y

        The sigstore service, hosted by sigstore a Series of LF Projects, LLC, is provided pursuant to the Hosted Project Tools Terms
 of Use, available at https://lfprojects.org/policies/hosted-project-tools-terms-of-use/.
        Note that if your submission includes personal data associated with this signed artifact, it will be part of an immutable rec
ord.
        This may include the email address associated with the account with which you authenticate your contractual Agreement.
        This information will be used for signing this artifact and will be stored in public transparency logs and cannot be removed
later, and is subject to the Immutable Record notice at https://lfprojects.org/policies/hosted-project-tools-immutable-records/.

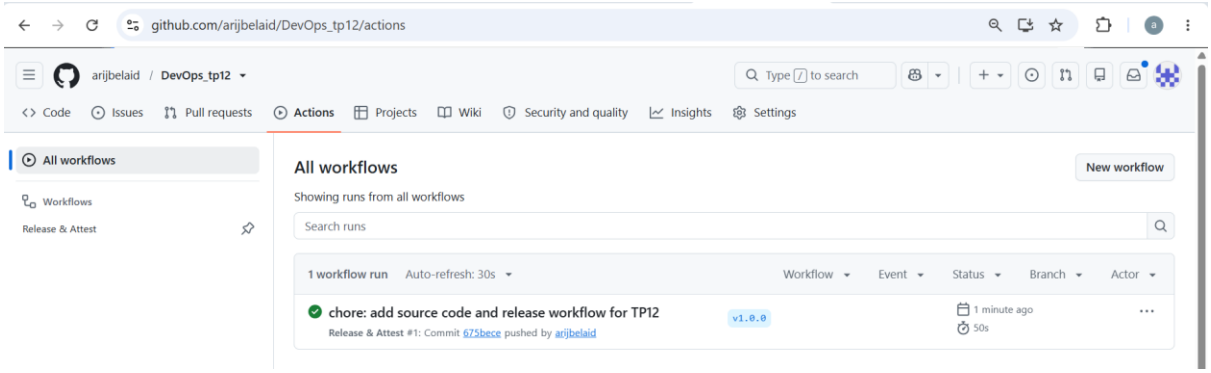
By typing 'y', you attest that (1) you are not submitting the personal data of any other person; and (2) you understand and agree to
the statement and the Agreement terms at the URLs listed above.
Are you sure you would like to continue? [y/N] y
tlog entry created with index: 3742387497
```

Partie 5 : Keyless et provenance dans GitHub Actions

1. Créer le tag et déclencher le workflow

```
arij@vagrant:~/DevOps_tp12$ git tag v1.0.0
arij@vagrant:~/DevOps_tp12$ git push origin v1.0.0
Total 0 (delta 0), reused 0 (delta 0), pack-reused 0
To github.com:arijbelaid/DevOps_tp12.git
 * [new tag]         v1.0.0 -> v1.0.0
arij@vagrant:~/DevOps_tp12$
```

2. Vérifier sur GitHub



3. Vérifier la signature depuis la VM

```
arij@vagrant:~/DevOps_tp12$ echo "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" | docker login ghcr.io -u arijbelaid --password-stdin

WARNING! Your credentials are stored unencrypted in '/home/arij/.docker/config.json'.
Configure a credential helper to remove this warning. See
https://docs.docker.com/go/credential-store/

Login Succeeded
arij@vagrant:~/DevOps_tp12$ cosign verify ghcr.io/arijbelaid/contact-api:v1.0.0 \
  --certificate-identity-regexp 'https://github.com/arijbelaid/DevOps_tp12/.*' \
  --certificate-oidc-issuer https://token.actions.githubusercontent.com

Verification for ghcr.io/arijbelaid/contact-api:v1.0.0 --
The following checks were performed on each of these signatures:
  - The cosign claims were validated
  - Existence of the claims in the transparency log was verified offline
  - The code-signing certificate was verified using trusted certificate authority certificates

[{"critical":{"identity":{"docker-reference":"ghcr.io/arijbelaid/contact-api"},"image":{"docker-manifest-digest":"sha256:1dcb230b33d0
8074c931788bef5da43a5b07a56ffee162d74c0efb7a1d47bb88"},"type":"cosign container image signature"},"optional":{"1.3.6.1.4.1.57264.1.1"
:"https://token.actions.githubusercontent.com","1.3.6.1.4.1.57264.1.2":"push","1.3.6.1.4.1.57264.1.3":"675bece20d3c97e2a68e6166f1b56d
7ca63e4a22","1.3.6.1.4.1.57264.1.4":"Release \u0026 Attest","1.3.6.1.4.1.57264.1.5":"arijbelaid/DevOps_tp12","1.3.6.1.4.1.57264.1.6":
"refs/tags/v1.0.0","Bundle":{"SignedEntryTimestamp":"MEQCIGZaJghFwvRQEx6XEOAb8Ple5v9OGoyCuQI38ttGxtGaAiA/ZHwQLYhDADvXspsPrJkCpSh+KKMG
6DubUlkF2OVxmw==","Payload":{"body":"eyJhcGlWZXJzaW9uIjoiMC4wLjEiLCJraW5kIjoiaGFzaGVkcmVrb3JkIiwic3BlYyI6eyJkYXRhIjp7Imhhc2giOnsiYWxn
```

4. Vérifier l'attestation de provenance

```
arij@vagrant:~/DevOps_tp12$ gh attestation verify oci://ghcr.io/arijbelaid/contact-api:v1.0.0 --owner arijbelaid
Loaded digest sha256:1dcb230b33d08074c931788bef5da43a5b07a56ffee162d74c0efb7a1d47bb88 for oci://ghcr.io/arijbelaid/contact-api:v1.0.0
Loaded 1 attestation from GitHub API

The following policy criteria will be enforced:
- Predicate type must match:................ https://slsa.dev/provenance/v1
- Source Repository Owner URI must match:... https://github.com/arijbelaid
- Subject Alternative Name must match regex: (?i)^https://github\.com/arijbelaid/
- OIDC Issuer must match:................... https://token.actions.githubusercontent.com

✓ Verification succeeded!

The following 1 attestation matched the policy criteria

- Attestation #1
  - Build repo:..... arijbelaid/DevOps_tp12
  - Build workflow:. .github/workflows/release.yml@refs/tags/v1.0.0
  - Signer repo:.... arijbelaid/DevOps_tp12
  - Signer workflow: .github/workflows/release.yml@refs/tags/v1.0.0
```